

Cybersecurity Daily Newsletter

Vol. 005 | 2026-09-19 09:00 WIB

Top 5 Highlights

- New CISA-hosted VINCE-NT system revealed for coordinated vulnerability disclosure
- Congress pledges mental health support after Cyber Command suicides
- AI reshapes exposure management around real-world risk, says Brinqa exec
- Cisco Zero-Day Highlights API Endpoint Authentication Issues
- Public Exploits Released for Four Linux Kernel Flaws That Enable Local Root

Threat Intelligence (10)

01. New Android malware uses AI to steal bank logins and PINs

RatHat can navigate infected phones while stealing bank logins, authentication codes, and screen-lock PINs.

Why it matters: Threat-actor tradecraft and active campaigns help defenders anticipate techniques likely to be used against their environment.

Recommendation: Update detections and threat hunts using reported TTPs/IOCs, review email/web controls, and harden high-risk internet-facing services.

Sources: <https://www.malwarebytes.com/blog/news/2026/09/new-android-malware-uses-ai-to-steal-bank-logins-and-pins>

02. Transparent Tribe Deploys New Rust Backdoor Using Private GitHub Repositories for C2

The Pakistan-aligned threat group tracked as Transparent Tribe (aka APT36 and Earth Karkaddan) has been attributed to a fresh set of cyber attacks targeting government and defense entities in India and Afghanistan. The attacks, per Zscaler ThreatLabz, involve the use of previously undocumented tools called RUSTYSHADE, RUSTYMOVE, PSNATCH, and BASHNATCH. The...

Why it matters: Threat-actor tradecraft and active campaigns help defenders anticipate techniques likely to be used against their environment.

Recommendation: Update detections and threat hunts using reported TTPs/IOCs, review email/web controls, and harden high-risk internet-facing services.

Sources: <https://thehackernews.com/2026/09/transparent-tribe-deploys-new-rust.html>

03. Fake LastPass Authenticator GitHub repos push new Rapuncel infostealer

An ongoing malware campaign uses SEO-optimized GitHub repositories to impersonate well-known software firms to push a previously undocumented information stealer called Rapuncel. [...]

Why it matters: Threat-actor tradecraft and active campaigns help defenders anticipate techniques likely to be used against their environment.

Recommendation: Update detections and threat hunts using reported TTPs/IOCs, review email/web controls, and harden high-risk internet-facing services.

Sources: <https://www.bleepingcomputer.com/news/security/fake-lastpass-authenticator-github-repos-push-new-rapuncel-infostealer/>

04. GhostCode attackers abuse device codes to take over Microsoft 365 accounts

Microsoft 365 users are being tricked into handing over access to their accounts by a new phishing kit, GhostCode, that exploits a weakness in a legitimate device authorization flow. Researchers in eSentire's threat response unit identified the campaign in late August 2026. The kit abuses Microsoft's OAuth 2.0 device authorization grant flow, a legitimate m...

Why it matters: Threat-actor tradecraft and active campaigns help defenders anticipate techniques likely to be used against their environment.

Recommendation: Tighten email authentication and filtering, run targeted user awareness, and monitor for lookalike domains and suspicious inbox rules.

Sources: <https://www.csoononline.com/article/4223898/ghostcode-attackers-abuse-device-codes-to-take-over-microsoft-365-accounts-2.html>

05. WeaselBiscuit Stealer Spreads via 13 npm Packages to Harvest Chrome Extension Storage

Cybersecurity researchers have discovered a cluster of 13 npm packages that have been found to deliver a previously undocumented JavaScript stealer codenamed WeaselBiscuit. The new malware family, per OpenSourceMalware, exhibits functional overlaps with two malware strains associated with the Democratic People's Republic of Korea's (DPRK) Contagious Interv...

Why it matters: Threat-actor tradecraft and active campaigns help defenders anticipate techniques likely to be used against their environment.

Recommendation: Update detections and threat hunts using reported TTPs/IOCs, review email/web controls, and harden high-risk internet-facing services.

Sources: <https://thehackernews.com/2026/09/weaselbiscuit-stealer-spreads-via-13.html>

06. NightmareStresser DDoS Service Disrupted in International Operation

Active since at least 2022, NightmareStresser was one of the longest-running DDoS-for-hire services in the world. The post NightmareStresser DDoS Service Disrupted in International Operation appeared first on SecurityWeek .

Why it matters: Threat-actor tradecraft and active campaigns help defenders anticipate techniques likely to be used against their environment.

Recommendation: Update detections and threat hunts using reported TTPs/IOCs, review email/web controls, and harden high-risk internet-facing services.

Sources:

<https://www.securityweek.com/nightmarestresser-ddos-service-disrupted-in-international-operation/>

07. [+24h Old] Brevo Supply Chain Attack Injects Malware Into 100,000 Websites

Hackers used a compromised API key to deploy a Cloudflare worker that injected malicious scripts. The post Brevo Supply Chain Attack Injects Malware Into 100,000 Websites appeared first on SecurityWeek .

Why it matters: Threat-actor tradecraft and active campaigns help defenders anticipate techniques likely to be used against their environment.

Recommendation: Audit build pipelines, rotate CI/CD secrets, enforce package integrity controls, and review developer workstation hardening.

Sources:

<https://www.securityweek.com/brevo-supply-chain-attack-injects-malware-into-100000-websites/>

08. [+24h Old] Claimed Bug Bounty Hunter Likely Used LLM to Build PhantomRaven npm Stealer

A financially motivated threat actor has been linked to the development and distribution of a JavaScript (JS)-based information stealer known as PhantomRaven via the npm package registry. "The developer likely wrote the malware using a large language model (LLM), an assessment made with high confidence based on verbose comments, placeholder code, and statis...

Why it matters: Threat-actor tradecraft and active campaigns help defenders anticipate techniques likely to be used against their environment.

Recommendation: Update detections and threat hunts using reported TTPs/IOCs, review email/web controls, and harden high-risk internet-facing services.

Sources: <https://thehackernews.com/2026/09/claimed-bug-bounty-hunter-likely-used.html>

09. [+24h Old] RatHat Android Malware Abuses ADB to Retain Shell Access After Uninstall

Cybersecurity researchers have flagged a new Android malware called RatHat that's assessed to be operated by China-based threat actors and features an artificial intelligence (AI)-powered system to navigate and control compromised devices. "Distributed primarily via targeted smishing (SMS/text phishing) and malvertising campaigns leading to deceptive third-...

Why it matters: Threat-actor tradecraft and active campaigns help defenders anticipate techniques likely to be used against their environment.

Recommendation: Tighten email authentication and filtering, run targeted user awareness, and monitor for lookalike domains and suspicious inbox rules.

Sources: <https://thehackernews.com/2026/09/rathat-android-malware-abuses-adb-to.html>

10. [+24h Old] ISC Stormcast For Friday, September 18th, 2026 <https://isc.sans.edu/podcastdetail/10100>, (Fri, Sep 18th)

ISC Stormcast For Friday, September 18th, 2026 <https://isc.sans.edu/podcastdetail/10100>, (Fri, Sep 18th)

Why it matters: Threat-actor tradecraft and active campaigns help defenders anticipate techniques likely to be used against their environment.

Recommendation: Update detections and threat hunts using reported TTPs/IOCs, review email/web controls, and harden high-risk internet-facing services.

Sources: <https://isc.sans.edu/diary/rss/33350>

Latest Vulnerabilities (10)

01. New CISA-hosted VINCE-NT system revealed for coordinated vulnerability disclosure

CISA says the new system is more streamlined and secure, enabling faster coordination.

Why it matters: Exploit-ready vulnerabilities can rapidly translate into compromise-especially for internet-facing services and widely deployed products.

Recommendation: Prioritize patching/mitigations, review exposure, and add detection for exploitation attempts (e.g., WAF/EDR signatures and logs).

Sources: <https://www.scworld.com/news/new-cisa-hosted-vince-nt-system-revealed-for-coordinated-vulnerability-disclosure>

02. Congress pledges mental health support after Cyber Command suicides

Lawmakers seek more mental health resources after five Cyber Command personnel died by suicide.

Why it matters: Exploit-ready vulnerabilities can rapidly translate into compromise-especially for internet-facing services and widely deployed products.

Recommendation: Prioritize patching/mitigations, review exposure, and add detection for exploitation attempts (e.g., WAF/EDR signatures and logs).

Sources:

<https://www.scworld.com/news/congress-pledges-mental-health-support-after-cyber-command-suicides>

03. AI reshapes exposure management around real-world risk, says Brinqa exec

AI-driven attacks are shifting exposure management toward exploitability and faster risk reduction.

Why it matters: Exploit-ready vulnerabilities can rapidly translate into compromise-especially for internet-facing services and widely deployed products.

Recommendation: Prioritize patching/mitigations, review exposure, and add detection for exploitation attempts (e.g., WAF/EDR signatures and logs).

Sources: <https://www.scworld.com/resource/ai-reshapes-exposure-management-around-real-world-risk-says-brinqa-exec>

04. Cisco Zero-Day Highlights API Endpoint Authentication Issues

The authentication bypass flaw CVE-2026-76460 impacts Cisco's Identity Services Engine (ISE) and received a maximum 10 out of 10 CVSS score.

Why it matters: Exploit-ready vulnerabilities can rapidly translate into compromise-especially for internet-facing services and widely deployed products.

Recommendation: Prioritize patching/mitigations, review exposure, and add detection for exploitation attempts (e.g., WAF/EDR signatures and logs).

Sources:

<https://www.darkreading.com/vulnerabilities-threats/cisco-zero-day-api-endpoint-authentication-issues>

05. Public Exploits Released for Four Linux Kernel Flaws That Enable Local Root

A security researcher has released working exploit code for four Linux kernel flaws that each let a local user gain root, the highest level of access on a machine. Kernel maintainers have fixed all four over the past few weeks, so a system running an up-to-date kernel is not affected. But the exploit code is now public, and any machine still running an older...

Why it matters: Exploit-ready vulnerabilities can rapidly translate into compromise-especially for internet-facing services and widely deployed products.

Recommendation: Prioritize patching/mitigations, review exposure, and add detection for exploitation attempts (e.g., WAF/EDR signatures and logs).

Sources: <https://thehackernews.com/2026/09/public-exploits-released-for-four-linux.html>

06. How teams can patch faster when a bug gets added to CISA's KEV

KEV remediation rates are low - here's what we need to do so teams can patch a KEV item before a ransomware attack hits.

Why it matters: Exploit-ready vulnerabilities can rapidly translate into compromise-especially for internet-facing services and widely deployed products.

Recommendation: Prioritize patching/mitigations, review exposure, and add detection for exploitation attempts (e.g., WAF/EDR signatures and logs).

Sources:

<https://www.scworld.com/perspective/how-teams-can-patch-faster-when-a-bug-gets-added-to-cisas-kev>

07. New WordPress Click2Shell Flaw Forces Theme Installs, Can Chain to Code Execution

WordPress today released patches to fix a new set of vulnerabilities in its core software, one of which could allow a crafted web link, opened by a logged-in administrator, to install a theme from the official WordPress.org directory without anyone clicking Install. The security firm pwn.ai, whose researchers reported the flaw, calls the attack chain Click2...

Why it matters: Exploit-ready vulnerabilities can rapidly translate into compromise-especially for internet-facing services and widely deployed products.

Recommendation: Prioritize patching/mitigations, review exposure, and add detection for exploitation attempts (e.g., WAF/EDR signatures and logs).

Sources: <https://thehackernews.com/2026/09/new-wordpress-click2shell-flaw-forces.html>

08. CISA is ending its monthly vulnerability bulletin

The rise in AI-generated security threats may just have generated one casualty: the death of the weekly bulletin of security threats from the US Cybersecurity Infrastructure and Security Agency (CISA). The agency will discontinue its weekly bulletin of known vulnerabilities from September 28...

Why it matters: Exploit-ready vulnerabilities can rapidly translate into compromise-especially for internet-facing services and widely deployed products.

Recommendation: Prioritize patching/mitigations, review exposure, and add detection for exploitation attempts (e.g., WAF/EDR signatures and logs).

Sources:

<https://www.csoonline.com/article/4223933/cisa-is-ending-its-monthly-vulnerability-bulletin.html>

09. Gyazo server flaw exploited to steal 23.6 million user records

The Gyazo image-sharing platform has confirmed it suffered a data breach after hackers exploited a server vulnerability that allowed them to steal 23.6 million user records. [...]

Why it matters: Exploit-ready vulnerabilities can rapidly translate into compromise-especially for internet-facing services and widely deployed products.

Recommendation: Prioritize patching/mitigations, review exposure, and add detection for exploitation attempts (e.g., WAF/EDR signatures and logs).

Sources: <https://www.bleepingcomputer.com/news/security/gyazo-server-flaw-exploited-to-steal-236-million-user-records/>

10. A zero-click RCE flaw in AI coding agents could have exposed enterprise systems

Popular AI coding agents such as OpenAI's Codex, Anthropic's Claude Code, Google's Gemini CLI, and Microsoft-owned GitHub Copilot were vulnerable to a zero-click attack that enabled attackers to execute malicious code, even without developer interaction, by swapping a trusted plugin from an online marketplace for a malicious one, potentially giving them a f...

Why it matters: Exploit-ready vulnerabilities can rapidly translate into compromise-especially for internet-facing services and widely deployed products.

Recommendation: Prioritize patching/mitigations, review exposure, and add detection for exploitation attempts (e.g., WAF/EDR signatures and logs).

Sources: <https://www.csoonline.com/article/4223909/a-zero-click-rce-flaw-in-ai-coding-agents-could-have-exposed-enterprise-systems-2.html>

Data Breach & Cybercrime (10)

01. New Settra Ransomware Variant Deployed in Attacks on Retail and Manufacturing

Huntress researchers highlighted a new ransomware variant, named Settra, and the post-compromise techniques used in two recent attacks

Why it matters: Ransomware operations combine disruption with extortion, making recovery speed and data-resilience core business risks.

Recommendation: Verify offline backups, test restores, harden remote access, and review segmentation to limit lateral movement.

Sources: <https://www.infosecurity-magazine.com/news/settra-ransomware-retail/>

02. Settra ransomware group uses MeshAgent RMM in recent attacks

The nascent threat actor has claimed 93 victims since June 2026.

Why it matters: Ransomware operations combine disruption with extortion, making recovery speed and data-resilience core business risks.

Recommendation: Verify offline backups, test restores, harden remote access, and review segmentation to limit lateral movement.

Sources:

<https://www.scworld.com/news/settra-ransomware-group-uses-meshagent-rmm-in-recent-attacks>

03. [+24h Old] Manufacturing Accounts for 22% of all Ransomware Victims

Black Kite has found that manufacturing remained the most targeted sector for ransomware attacks, and saw a big jump in incidents in H1 2026

Why it matters: Ransomware operations combine disruption with extortion, making recovery speed and data-resilience core business risks.

Recommendation: Verify offline backups, test restores, harden remote access, and review segmentation to limit lateral movement.

Sources: <https://www.infosecurity-magazine.com/news/manufacturing-22-ransomware-victims/>

04. [+24h Old] AI Agent Breaches Spanish Organization, Modifies Personal Data

AI-driven cyberattacks used to be exotic. Soon, it'll be odd if threat actors aren't using agents to do all of their bidding.

Why it matters: Breaches and cybercrime activity signal where attackers are focusing and what data types are actively monetized.

Recommendation: Validate incident-response readiness, monitor for exposed credentials, and reinforce MFA, phishing resistance, and data-loss controls.

Sources: <https://www.darkreading.com/cyberattacks-data-breaches/ai-agent-breaches-spanish-organization-personal-data>

05. [+24h Old] 98% of fraudulent hires have company credentials by the time they're caught

A 90-day period between hiring and onboarding is creating a blind spot in enterprise identity security, according to HYPR's State of HR Identity Fraud Detection report.

"Adversaries no longer need to breach a network when they can pass a remote interview and receive authentic credentials directly from IT," said Bojan Simic, CEO of HYPR.

"Human intuition is...

Why it matters: Breaches and cybercrime activity signal where attackers are focusing and what data types are actively monetized.

Recommendation: Validate incident-response readiness, monitor for exposed credentials, and reinforce MFA, phishing resistance, and data-loss controls.

Sources: <https://www.helpnetsecurity.com/2026/09/18/hypr-hiring-fraud-detection-report/>

06. [+24h Old] Most WordPress pros still lack a breach recovery plan

Melapress, a maker of WordPress security plugins, surveyed 319 WordPress professionals and found that most had dealt with at least one known security incident. The respondents build and run WordPress sites for a living: agency staff, developers, designers, site owners and administrators. Across the whole group, fewer than three in ten have a breach recovery...

Why it matters: Breaches and cybercrime activity signal where attackers are focusing and what data types are actively monetized.

Recommendation: Validate incident-response readiness, monitor for exposed credentials, and reinforce MFA, phishing resistance, and data-loss controls.

Sources: <https://www.helpnetsecurity.com/2026/09/18/wordpress-security-survey-recovery-plan/>

07. [+24h Old] Security spending is growing - except for the typical CISO

Security budgets may be growing on paper, but for a majority of CISOs, the money isn't moving in quite the same direction. The budgets grew by 5% on average in 2026, up from 4% last year. But that average hides a much weaker picture: median budget growth remained at 0%. And while 64% of CISOs asked for an increase this cycle, only 45% received one, meaning...

Why it matters: Breaches and cybercrime activity signal where attackers are focusing and what data types are actively monetized.

Recommendation: Validate incident-response readiness, monitor for exposed credentials, and reinforce MFA, phishing resistance, and data-loss controls.

Sources:

<https://www.csoonline.com/article/4223455/security-spending-is-growing-except-for-the-typical-ciso.html>

08. [+24h Old] Revolut phishing texts appear days after data breach

Revolut customers received phishing texts only days after the digital bank acknowledged disclosing customer data to a government impostor.

Why it matters: Breaches and cybercrime activity signal where attackers are focusing and what data types are actively monetized.

Recommendation: Validate incident-response readiness, monitor for exposed credentials, and reinforce MFA, phishing resistance, and data-loss controls.

Sources: <https://www.malwarebytes.com/blog/threat-intel/2026/09/revolut-phishing-texts-appear-days-after-data-breach>

09. [+24h Old] OpenAI Says Its Models Searched GitHub for Leaked API Keys During Training

OpenAI published a framework for disclosing model misalignment alongside six reports describing problematic behavior. The post OpenAI Says Its Models Searched GitHub for Leaked API Keys During Training appeared first on SecurityWeek .

Why it matters: Breaches and cybercrime activity signal where attackers are focusing and what data types are actively monetized.

Recommendation: Validate incident-response readiness, monitor for exposed credentials, and reinforce MFA, phishing resistance, and data-loss controls.

Sources: <https://www.securityweek.com/openai-says-its-models-hunted-github-for-leaked-api-keys-during-training/>

10. [+24h Old] London property manager breach may have exposed bank details and lockbox codes

City Relay says intruders accessed its Metabase Cloud instance twice and extracted customer data

Why it matters: Breaches and cybercrime activity signal where attackers are focusing and what data types are actively monetized.

Recommendation: Validate incident-response readiness, monitor for exposed credentials, and reinforce MFA, phishing resistance, and data-loss controls.

Sources: <https://www.theregister.com/security/2026/09/17/london-property-manager-breach-may-have-exposed-bank-details-and-lockbox-codes/5297232>